

FOR DEV - ANSWERED

Implementation decisions, contracts, deployment requirements, and known follow-ups

Prepared 11 September 2026. This document describes the current implemented repository state and should be regenerated when material behavior changes.

1. Purpose and Reading Order

This is the developer handoff for the current DisasTRACE implementation. It answers the recurring architecture and behavior questions that affect future changes. Read it with `context/project-overview.md`, `context/architecture-context.md`, `context/code-standards.md`, `context/ai-workflow-rules.md`, and `context/progress-tracker.md`.

Change rule

When a feature changes a state machine, security boundary, public API, migration, or deployment prerequisite, update the relevant context file and regenerate these PDFs in the same change.

2. Answered Architecture Decisions

Why REST plus Realtime?

REST route handlers own validation, authorization, transactional state changes, file handling, and server-only integrations. Supabase Realtime distributes committed changes to authenticated clients. This avoids treating a client event or a websocket message as authoritative.

Why PostgreSQL and Drizzle?

Incidents, verification requests, dispatch offers, responders, reports, quotas, and audit events have relational constraints and concurrency requirements. Drizzle provides typed access and migration ownership; application code must not use raw SQL for ordinary data access.

Why official barangay polygons?

A reporter-entered address or free-text landmark is not a reliable service-area authority. GPS is checked against the official 27-polygon Baliwag boundary set; the derived barangay is the display and assignment label while the captured coordinates remain the dispatch truth.

Why token-scoped guest status?

Guests have no Supabase session. Giving them anonymous database Realtime or Storage writes would widen the attack surface. A random per-report access token and a narrow polling endpoint provide status without exposing protected tables.

Why hashes for device controls?

The device identifier is needed for one-device sessions and guest abuse resistance, but storing the raw Android identifier is unnecessary. SHA-256 digests support matching and quotas while reducing retained identifying data. This is an abuse-control signal, not hardware attestation.

3. Authentication and Authorization Contract

- Roles: `public_user`, `ambulance_responder`, `pacc_admin`, `cdrrmo_super_admin`.
- Roles are stored in `public.users` and synchronized into `auth.users raw_app_meta_data` by database trigger.

- The proxy, API route handlers, and database RLS all enforce the boundary. Never rely on a mobile client gate alone.
- A mobile account has one active `mobile_device_sessions` row containing a device digest and JWT `session_id`. Browser dashboard sessions do not participate in this binding.
- Suspended/deactivated residents are blocked at sign-in and receive an explicit Account Banned state if status changes during a session.

Important session behavior

Successful mobile sign-in revokes other Supabase sessions and atomically binds the current one. Sign-out clears local credentials immediately and attempts matching server release with a short timeout. A replacement device requires administrator release or the logout-first flow.

4. Intake, AI, and Triage Contract

Validated fields

Guest and resident chatbot flows require callback/contact routing, automatic in-boundary GPS, nearby landmark/reference, incident details, exact affected-person count, condition, and evidence. Registered users use the verified phone on the account; the client cannot substitute an arbitrary number.

Classification contract

The allowed triage reasons are `HIGH_CONFIDENCE_EMERGENCY`, `HIGH_CONFIDENCE_NON_EMERGENCY`, `UNCERTAIN_INCOMPLETE`, and `SUSPICIOUS_POSSIBLE_PRANK`. Client hints are normalized server-side. Patient Transport, Other / non-emergency request, and Unknown Cause are non-emergency; remaining categories are not allowed to downgrade emergency handling.

The server-only DeepSeek gateway and local typed signal rules improve guided intake but never bypass confirmation, API validation, PACC review, or the dispatch engine. Raw training examples stay local and are not sent to the model or mobile clients.

Guest quota contract

The configurable lifetime limit applies to both normalized Philippine phone and app-scoped device digest. Same phone/device retries for the same submission are idempotent. New reports return 429 when either quota is exhausted. Obvious synthetic numbers are rejected at client and API boundaries.

5. Dispatch State and Concurrency Contract

Automatic dispatch is FIFO over confirmed pending emergencies. Eligibility requires active, approved, on-duty responder status and a trusted location heartbeat no older than one minute. The scheduler runs every five seconds through Supabase Cron/pg_net and is the authority for expiry, with API reconciliation as a recovery path.

Race prevention

- Automatic dispatch, Override Dispatch, PACC rejection, expiry cascading, and acceptance re-read state inside a transaction and lock the verification-request row.
- Responder reservation is atomic; an offer cannot be accepted after expiry at the database boundary.
- Expiry/reassignment first claims the still-current offer, so it cannot win over an in-flight acceptance.
- An exhausted offer becomes PACC reassignment required rather than silently disappearing.
- A public or guest status read can reconcile its own expired offer before returning state when the scheduler has not yet run.

Client rule

Do not infer dispatch ownership from a notification, countdown, or cached state. Hydrate the exact offer/incident from an authorized API and treat server state as final. Push and local notifications are advisory and must not mutate workflow state.

6. Location, Mapping, and Tracking Contract

- Foreground location is a non-dismissible prerequisite for every resident and responder tab. Returning from Settings triggers a permission recheck.
- Mock provider locations are rejected before report or telemetry use. Implausible responder movement keeps the last trusted position and writes a rate-limited audit record.
- Report GPS is authoritative. EXIF GPS from evidence is optional metadata; a material mismatch routes the report to PACC review.
- Map labels use GPS-derived Barangay Name, Baliwag City. Landmarks are never shown as the incident location.
- Web maps subscribe to active incident telemetry and render concurrent route caches. Guest maps use only the scoped status endpoint.

Remaining security follow-up

Implement Google Play Integrity with request-bound tokens and server verification after release signing and Play Console/Cloud configuration. Do not replace this with a client-only boolean.

7. Responder Reports and Offline Contract

/api/reports accepts incident-linked responder documentation, including patient_care_reports and driver_trip_tickets. The mobile responder store must serialize both objects and signatures in online and offline payloads. A deliberate Save as Draft is distinct from a crash/background recovery draft and should update the active incident UI accordingly.

Signature paths are stored as serialized SVG path data, rendered with react-native-svg on mobile and SVG on web, then rasterized for jsPDF embedding. PDF layout must calculate multiline heights dynamically; fixed offsets have previously caused overlapping dispatch, address, and narrative text.

Native scheduled notifications, not a JavaScript timer, drive the five-minute reminder while unsent drafts exist and connectivity is available. Submission cancels the reminder.

8. Realtime and Notification Contract

Authenticated Realtime covers incidents, offers, telemetry, statuses, notifications, and coordination updates. Guest status does not subscribe anonymously; it polls every three seconds. Notification rows support all/unread filtering and linked navigation. Responder offers use foreground/local Android alerts plus Expo Push/FCM when backgrounded; push tokens are tied to the active mobile session and removed on sign-out or provider invalidation.

9. Migrations and Deployment Checklist

- Run the full Drizzle journal in order; ensure dispatch-offer expiry migration 0016 is registered in the migration journal.
- Apply database functions, RLS/RBAC, realtime publication setup, logging triggers, spatial/barangay boundary setup, and storage policies.
- Configure Supabase Cron/pg_net to call the protected expiry engine every five seconds with its server secret.
- Configure textbee.dev, Expo Push/FCM, Supabase Auth redirect URLs, disaTRACE://reset-password, and production APP_URL.
- Initialize system settings, guest limit, deduplication radius, hospitals, and official barangay data.
- Verify one-device session behavior, guest phone/device quotas, location integrity, dispatch recovery, chatbot contract, and Baliwag barangay resolution using the repository scripts before release.

Useful verification commands

- npx tsc --noEmit
- npx tsx scripts/verify-chatbot-contract.ts
- npx tsx scripts/verify-dispatch-recovery.ts
- npx tsx scripts/verify-guest-phone-limit.ts
- npx tsx scripts/verify-location-integrity.ts
- npx tsx scripts/verify-baliwag-barangays.ts

10. Resolved Questions and Non-Goals

Resolved: PACC is triage/dispatch only; CDRRMO Super Admin owns approvals. Guest intake is countless and scoped. Automatic dispatch is FIFO and recoverable. Multi-ambulance tracking is supported. PCR/DTT signatures and offline drafts are supported. Official polygons, server-side deduplication, one-device sessions, and quota hashes are authoritative.

Non-goals: iOS, billing, predictive emergency detection, fully automated fire/flood/police response, employee performance monitoring, and guaranteed push delivery after Android has killed the app. Play Integrity remains a planned hardening step, not a claimed current capability.